

STRATUM CAPITAL BANK

Enterprise Governance & Risk Framework

CHAPTER 12

Enterprise Regulatory Compliance, Legal Governance & Corporate Ethics Framework

Document Classification	CONFIDENTIAL — INTERNAL USE ONLY
Version	5.4.1
Effective Date	1 January 2025
Review Cycle	Annual
Document Owner	Chief Compliance Officer
Approved By	Board Risk & Compliance Committee
Chapter Status	FINAL — GOVERNING CHAPTER

This document is classified CONFIDENTIAL — INTERNAL USE ONLY. Unauthorised disclosure, reproduction or distribution is strictly prohibited and may constitute a breach of applicable law, regulatory obligations and Stratum Capital Bank internal policies.

DOCUMENT CONTROL INFORMATION

ATTRIBUTE	DETAIL
Framework Title	Enterprise Governance & Risk Framework
Chapter Number	Chapter 12 (Final Chapter)
Chapter Title	Enterprise Regulatory Compliance, Legal Governance & Corporate Ethics Framework
Document Number	SCB-GOV-CH12-v5.4.1

Version Number	5.4.1
Effective Date	1 January 2025
Supersedes	Version 5.3.0 dated 1 January 2024
Review Date	31 December 2025
Classification	CONFIDENTIAL — INTERNAL USE ONLY
Document Owner	Chief Compliance Officer
Custodian	Head of Compliance Policy & Governance
Sponsor	Board Risk & Compliance Committee
Approved By	Board of Directors — Resolution No. SCB/BRD/2024/147
Geographic Scope	All jurisdictions in which Stratum Capital Bank operates
Entity Scope	Stratum Capital Bank N.V. and all subsidiaries and branches

Version History

Version	Date	Author	Summary of Changes
5.4.1	Jan 2025	CCO Office	Integration of AI Governance reporting obligations; updated whistleblower provisions; enhanced third-party compliance standards; expanded breach management framework
5.3.0	Jan 2024	CCO Office	Consolidated conduct risk framework; updated gift and hospitality thresholds; revised training requirements
5.2.0	Jan 2023	CCO Office	Initial publication of unified chapter; superseded standalone compliance and ethics policies

12.1 Purpose of the Compliance Framework

This Chapter constitutes the final and governing chapter of Stratum Capital Bank's (hereinafter 'the Bank' or 'SCB') Enterprise Governance & Risk Framework (hereinafter 'the Framework'). It establishes the enterprise-wide regulatory compliance, legal governance, and corporate ethics architecture that operates as the overarching governance umbrella for all preceding chapters (Chapters 1 through 11) of the Framework. All provisions, standards, and obligations set out in this Chapter shall take precedence in matters of governance integration, compliance supremacy, and regulatory accountability.

12.1.1 Objectives

The Compliance Framework of Stratum Capital Bank is designed to achieve the following primary objectives:

- To establish a structured, risk-based, and proportionate compliance management system consistent with ISO 37301:2021 (Compliance Management Systems) that enables the Bank to identify, assess, manage, and report compliance risks across all jurisdictions in which it operates.
- To embed a culture of compliance, integrity, and ethical conduct throughout the organisation, from the Board of Directors to all individual employees, contractors, and agents of the Bank.
- To ensure the Bank meets all applicable regulatory, statutory, and supervisory obligations imposed by competent authorities across all operating jurisdictions, including but not limited to central banks, prudential regulators, securities regulators, and anti-money laundering authorities.
- To provide clear governance structures, accountability frameworks, and escalation pathways that ensure compliance matters are identified, reported, and remediated in a timely and effective manner.
- To protect the Bank, its employees, its customers, and its shareholders from the reputational, financial, and legal consequences of regulatory non-compliance and ethical failure.
- To integrate compliance requirements into the Bank's risk management architecture, business planning processes, and operational controls in a manner consistent with the principles articulated in Basel Committee on Banking Supervision (BCBS) Compliance Principles (2005, as updated) and the Financial Stability Board (FSB) governance standards.
- To maintain and continuously improve the effectiveness of the compliance framework through regular monitoring, testing, review, and benchmarking against international best practice.

12.1.2 Regulatory Expectations

Stratum Capital Bank operates as a Globally Systemically Important Bank (G-SIB) and is subject to the heightened supervisory expectations applicable to institutions of its systemic significance. The regulatory compliance framework is designed to satisfy the expectations of the following primary regulatory bodies and frameworks:

- Basel Committee on Banking Supervision (BCBS) — Principles for the Sound Management of Operational Risk; Compliance and the Compliance Function in Banks (April 2005); and all associated guidance notes.
- Financial Action Task Force (FATF) — Recommendations on Anti-Money Laundering and Counter-Terrorist Financing; Guidance for the Banking Sector; Risk-Based Approach Guidance.
- International Organisation for Standardisation — ISO 37301:2021 (Compliance Management Systems); ISO 37001:2016 (Anti-Bribery Management Systems); ISO 31000:2018 (Risk Management).
- Organisation for Economic Co-operation and Development (OECD) — G20/OECD Principles of Corporate Governance (2023 edition); OECD Convention on Combating Bribery of Foreign Public Officials.
- Committee of Sponsoring Organisations (COSO) — Internal Control — Integrated Framework (2013); Enterprise Risk Management — Integrating with Strategy and Performance (2017).
- Home and host jurisdiction supervisory requirements across all operating jurisdictions, including applicable prudential, conduct, anti-money laundering, sanctions, consumer protection, and data protection regulatory frameworks.
- All applicable laws, regulations, regulatory guidance, directives, codes of practice, and binding supervisory determinations.

12.1.3 Compliance Philosophy

Stratum Capital Bank's compliance philosophy is grounded in the principle that regulatory compliance is not merely a legal obligation, but a fundamental expression of the Bank's values, its commitment to its customers, and its responsibility to the financial system and broader society. The Bank adopts the following philosophical principles in the design and operation of its compliance framework:

- **Compliance as Culture:** Compliance obligations are owned by every individual within the organisation. A compliance-first culture is established through tone at the top, consistent management behaviour, and individual accountability.
- **Proportionality and Risk-Based Approach:** Compliance resources, controls, and monitoring activities are allocated proportionately to the nature, scale, and complexity of identified compliance risks, consistent with the risk-based approach advocated by the Basel Committee and FATF.
- **Proactive Compliance:** The Bank anticipates regulatory change through horizon scanning and forward-looking risk assessment, rather than responding reactively to regulatory events.
- **Zero Tolerance for Material Breach:** The Bank maintains a zero-tolerance position in relation to material regulatory non-compliance, financial crime facilitation, bribery, corruption, market abuse, and ethical misconduct.
- **Transparency and Openness:** The Bank fosters open and transparent relationships with its regulators, providing timely, accurate, and complete information as required.

12.1.4 Governance Principles

The Compliance Framework is governed by the following enterprise governance principles, which are consistent with the OECD Corporate Governance Principles and the Bank's broader governance architecture set out in Chapter 1 of this Framework:

- **Board Accountability:** The Board of Directors bears ultimate accountability for establishing and maintaining an effective compliance culture and framework.
- **Three Lines of Defence:** Compliance governance is structured around the internationally accepted Three Lines of Defence model. Business units constitute the First Line; Compliance, Risk, and Legal functions constitute the Second Line; and Internal Audit constitutes the Third Line.
- **Independence:** The Compliance function operates with organisational and functional independence from the business lines it oversees, reporting directly to the Board Risk & Compliance Committee.
- **Segregation of Duties:** Compliance monitoring, policy development, and enforcement activities are appropriately segregated from business origination and operational activities.
- **Continuous Improvement:** The compliance framework is subject to regular review, independent assessment, and enhancement in response to changes in the regulatory environment, organisational risk profile, and lessons learned from internal and external events.

12.1.5 Institution-Wide Responsibilities

Compliance with this Chapter and all applicable regulatory obligations is the responsibility of every individual within Stratum Capital Bank, irrespective of grade, function, geography, or contractual status. Specific responsibilities are allocated as follows:

- **Board of Directors:** Bears ultimate accountability for the compliance framework. Approves the Framework and its component chapters. Reviews compliance risk reports and regulatory developments. Ensures adequate resources are allocated to the Compliance function.
- **Senior Management:** Implements the Board-approved compliance framework within their areas of responsibility. Sets compliance objectives and performance expectations for their teams. Escalates material compliance concerns to the Board.
- **Chief Compliance Officer:** Leads and manages the enterprise-wide Compliance function. Reports to the Board and senior management on the state of compliance. Serves as the primary point of contact with external regulators on compliance matters.
- **All Employees:** Understand and comply with applicable laws, regulations, and internal policies. Complete mandatory compliance training. Report actual or suspected compliance breaches through appropriate channels. Do not engage in conduct that could compromise the Bank's compliance obligations.

12.2 Regulatory Governance

The regulatory governance structure of Stratum Capital Bank defines the roles, responsibilities, and accountability relationships of all principal governance actors in relation to the identification, management, monitoring, and reporting of compliance risks. The structure is consistent with the BCBS Compliance Principles, the Basel Corporate Governance Principles (BCBS 328, 2015), and the Bank's enterprise governance architecture established in Chapter 1 of this Framework.

12.2.1 Board of Directors

The Board of Directors holds ultimate accountability for the regulatory compliance posture of Stratum Capital Bank. In exercising its compliance governance responsibilities, the Board shall:

- Approve this Chapter and all other components of the Enterprise Governance & Risk Framework on an annual basis, or as circumstances require.
- Receive and critically review quarterly Compliance Risk Reports prepared by the Chief Compliance Officer, including summaries of identified breaches, regulatory developments, and remediation status.
- Satisfy itself that the Bank has in place adequate compliance resources, systems, and processes to meet all applicable regulatory obligations.
- Ensure that the Compliance function has sufficient organisational independence, appropriate seniority, and direct access to the Board and its Committees.
- Approve the Bank's Compliance Risk Appetite Statement and material deviations therefrom.
- Review and approve all material regulatory breach notifications prior to submission to external regulators, where time permits and regulatory requirements allow.
- Discharge its compliance governance responsibilities primarily through the Board Risk & Compliance Committee, as constituted under Chapter 1 of this Framework.

12.2.2 Chief Compliance Officer

The Chief Compliance Officer (CCO) is a member of the Executive Committee and a Key Function Holder for regulatory purposes. The CCO holds personal accountability for the design, implementation, and operational effectiveness of the enterprise-wide compliance framework. The CCO's specific responsibilities include:

- Establishing, maintaining, and continuously improving the enterprise compliance framework in all material respects.
- Providing independent, objective, and timely advice to the Board, Committees, and management on all material compliance matters.
- Overseeing the compliance monitoring and testing programme, including thematic reviews, control testing, and transaction surveillance.
- Managing the Bank's relationship with primary regulatory authorities, including providing regulatory notifications as required.
- Leading the identification, assessment, and escalation of compliance risks across all business lines and jurisdictions.
- Ensuring the delivery of an effective mandatory compliance training programme for all staff.
- Reporting to the Board Risk & Compliance Committee on a quarterly basis, and to the Executive Committee on a monthly basis, on the state of compliance across the enterprise.

- Maintaining the Bank's regulatory breach register and overseeing the timely remediation of identified deficiencies.

12.2.3 Chief Risk Officer

The Chief Risk Officer (CRO) maintains collective accountability with the CCO for the identification and management of compliance-related risks that arise from, or contribute to, the enterprise risk profile of the Bank. The CRO shall:

- Integrate compliance risk assessments into the enterprise risk management framework established in Chapter 2 of this Framework.
- Ensure that the Risk Management function and the Compliance function operate with appropriate coordination and information sharing arrangements.
- Review and challenge material compliance risk assessments and the adequacy of controls identified by the Compliance function.
- Report compliance-related risk exposures to the Board Risk Committee and Asset & Liability Committee (ALCO) as required.

12.2.4 General Counsel

The General Counsel (GC) provides the Board, Executive Committee, and the Compliance function with authoritative legal advice on regulatory matters, legislative interpretation, and legal risk. The GC shall:

- Advise on the legal interpretation of applicable laws, regulations, and regulatory guidance across all operating jurisdictions.
- Manage the Bank's relationships with external legal counsel and ensure the quality and independence of legal opinions obtained by the Bank.
- Oversee litigation management and provide the Board with timely reporting on material legal proceedings.
- Manage the contract governance framework in coordination with business lines and the Compliance function.
- Advise on cross-border legal requirements applicable to the Bank's operations, including jurisdictional conflicts and applicable law determinations.

12.2.5 Business Units (First Line of Defence)

Business unit management and employees constitute the First Line of Defence and bear primary operational accountability for compliance with applicable laws, regulations, and internal policies within their areas of business. Business unit compliance responsibilities include:

- Implementing and operating controls designed to ensure compliance with applicable regulatory requirements and internal policies.
- Identifying, assessing, and managing compliance risks within their business activities as part of the operational risk management process (see Chapter 6 of this Framework).
- Escalating identified or suspected compliance issues, breaches, or control failures to the Compliance function and line management without undue delay.
- Cooperating fully with compliance monitoring activities, internal audits, and regulatory examinations.
- Ensuring that all staff within the business unit complete mandatory compliance training and maintain their individual certifications.

12.2.6 Compliance Officers (Second Line of Defence)

The Compliance function, comprising the CCO and all Compliance Officers operating across business lines and jurisdictions, constitutes the Second Line of Defence. Compliance Officers are responsible for:

- Providing compliance advisory support to assigned business lines, including advice on regulatory interpretation and product approvals.
- Executing the compliance monitoring and testing programme within assigned areas.
- Reviewing and approving new products, services, and material business changes for compliance purposes.
- Maintaining knowledge of applicable regulatory requirements and communicating relevant regulatory developments to assigned business areas.
- Maintaining independence from the business lines they oversee and escalating compliance concerns to the CCO without management interference.

12.2.7 Internal Audit (Third Line of Defence)

The Internal Audit function provides independent, objective assurance to the Board and Audit Committee on the effectiveness of the compliance framework and associated controls. Internal Audit's compliance-related responsibilities include:

- Conducting risk-based audits of the design and operating effectiveness of compliance controls across all business lines and jurisdictions.
- Assessing the adequacy of the compliance monitoring and testing programme operated by the Second Line of Defence.
- Reporting audit findings and associated recommendations to the Board Audit Committee on a quarterly basis.
- Tracking and verifying the timely closure of compliance-related audit findings.
- Conducting follow-up procedures to validate the remediation of material compliance control deficiencies.

12.2.8 External Regulators

Stratum Capital Bank is subject to the oversight of competent regulatory authorities across all jurisdictions in which it operates. The Bank's approach to regulatory relationships shall be characterised by the following principles:

- Openness and transparency in all dealings with regulatory authorities.
- Timely, accurate, and complete responses to all regulatory requests, enquiries, and supervisory examinations.
- Proactive engagement with regulatory authorities on material risks, significant issues, and emerging concerns.
- Strict adherence to all regulatory notification timelines and reporting obligations.
- Board and senior management direct engagement with regulatory authorities as required.

12.3 Enterprise Compliance Framework

The Enterprise Compliance Framework sets out the structured methodology through which Stratum Capital Bank identifies, assesses, manages, monitors, and reports compliance risks across the entirety of its

operations. The framework is designed in accordance with the requirements of ISO 37301:2021 (Compliance Management Systems) and the BCBS Compliance Principles.

12.3.1 Compliance Risk Identification

Compliance risk identification is a continuous, systematic, and documented process that encompasses all business activities, products, services, distribution channels, geographies, and counterparty relationships of the Bank. The identification methodology includes:

- Maintenance of a comprehensive Compliance Risk Inventory that catalogues all applicable laws, regulations, regulatory guidance, codes of practice, and internal policies relevant to the Bank's operations.
- Annual Compliance Risk Assessment (CRA), conducted for all business lines and legal entities, to identify and evaluate the nature, materiality, and likelihood of compliance risks across the enterprise.
- New Business Acceptance processes requiring all proposed new products, services, and material business changes to be subject to a compliance risk assessment prior to launch or implementation.
- Integration with the Operational Risk Management framework (Chapter 6) to ensure compliance risks are captured within the enterprise risk taxonomy and Risk and Control Self-Assessment (RCSA) process.
- Reactive identification procedures triggered by external events, including regulatory enforcement actions against peer institutions, judicial decisions, regulatory consultations, and industry guidance.

12.3.2 Regulatory Monitoring

The Compliance function maintains a structured regulatory monitoring process to ensure the Bank maintains current and accurate awareness of all applicable regulatory obligations across its operating jurisdictions. The regulatory monitoring framework shall incorporate:

- Subscriptions to regulatory publishing services and official regulatory websites across all jurisdictions.
- Systematic review of all regulatory publications, including final rules, consultation papers, guidance notes, enforcement notices, and supervisory letters.
- Circulation of material regulatory developments to relevant business lines and senior management through a formalised Regulatory Alert process.
- Maintenance of a Regulatory Change Register, tracking the status of all identified regulatory developments and associated implementation activities.
- Escalation of material regulatory developments to the Executive Compliance Committee and, where required, to the Board Risk & Compliance Committee.

12.3.3 Regulatory Horizon Scanning

In addition to monitoring current regulatory obligations, the Compliance function operates a forward-looking regulatory horizon scanning programme. This programme enables the Bank to anticipate material regulatory changes and prepare implementation plans in advance of effective dates. The horizon scanning programme shall:

- Assess regulatory developments that are expected to take effect within the next 12 to 36 months.
- Identify the potential impact of anticipated regulatory changes on the Bank's operations, products, and risk management frameworks.
- Facilitate the early engagement of business lines, technology, and operational functions in the preparation of regulatory implementation programmes.
- Include participation in relevant industry associations, regulatory working groups, and supervisory consultative processes to influence regulatory development outcomes where appropriate.

12.3.4 Policy Mapping

The Compliance function maintains a comprehensive regulatory-to-policy mapping, which links each applicable regulatory obligation to the corresponding internal policy, procedure, and control. The Policy Mapping framework shall:

- Provide complete traceability from each material regulatory requirement to the relevant internal policy document.
- Be maintained and updated as part of the annual Policy Review cycle and in response to material regulatory changes.
- Serve as the basis for the Compliance Risk Inventory and the Compliance Monitoring programme.
- Be accessible to Internal Audit and relevant regulatory authorities upon request.

12.3.5 Control Mapping

The Compliance function maintains a control mapping that links identified compliance risks to the relevant preventive and detective controls operated by the First and Second Lines of Defence. The control mapping shall be integrated with the COSO Internal Control Framework and the enterprise Risk and Control Self-Assessment process established in Chapter 6 of this Framework.

12.3.6 Compliance Assessments

The Compliance function conducts periodic compliance assessments at the enterprise, legal entity, business line, and jurisdictional levels. These assessments evaluate the adequacy and operating effectiveness of the compliance framework and serve as the basis for the Compliance Monitoring Programme described in Section 12.8 of this Chapter.

12.3.7 Risk-Based Compliance

In accordance with the BCBS Compliance Principles and FATF Risk-Based Approach Guidance, all compliance activities within Stratum Capital Bank are prioritised and calibrated on the basis of an objective assessment of the nature, likelihood, and potential impact of identified compliance risks. Resource allocation, monitoring intensity, and control requirements are scaled proportionately to the level of assessed compliance risk.

12.4 Legal Governance

The Legal Governance framework establishes the principles, structures, and standards through which Stratum Capital Bank manages its legal risk exposures and ensures that its operations, products, and counterparty relationships are appropriately founded in law and are legally sound. Legal governance is a core component of the Bank's Second Line of Defence and is integrated with the enterprise risk management framework established in Chapter 2.

12.4.1 Legal Risk

Legal risk is defined as the risk of loss arising from the failure to comply with applicable laws or regulations, or from legal uncertainty regarding the enforceability of contracts, the interpretation of legal obligations, or the outcome of litigation or regulatory proceedings. Legal risk is a component of operational risk as defined in Chapter 6 of this Framework. The Bank manages legal risk through the following measures:

- Maintenance of an enterprise Legal Risk Register, updated quarterly, which catalogues all material legal risks, associated probability assessments, estimated financial exposure, and risk mitigation actions.
- Integration of legal risk assessment into the New Business Acceptance process, the product approval process, and all material counterparty onboarding activities.
- Ensuring that all material legal risks are captured within the enterprise operational risk management framework and are subject to the same governance standards as other operational risk categories.
- Escalation of material or emerging legal risks to the General Counsel, the CCO, the CRO, and, where appropriate, to the Board.

12.4.2 Contract Governance

All contracts entered into by Stratum Capital Bank, whether with customers, counterparties, service providers, or agents, shall be subject to the Contract Governance Framework. The framework requires:

- Review of all material contracts by qualified legal counsel prior to execution, with particular attention to governing law, jurisdiction, enforceability, limitation of liability, indemnification, and termination provisions.
- Use of Bank-approved master agreement templates and standard contractual terms for common transaction and relationship types, with deviations subject to legal approval.
- Maintenance of a centralised contract management system that provides complete visibility of the Bank's contractual obligations, renewal dates, and counterparty exposures.
- Compliance review of contracts involving data processing, outsourcing, or agency arrangements to ensure alignment with applicable regulatory requirements, including data protection legislation.

12.4.3 Legal Opinions

Stratum Capital Bank shall obtain formal written legal opinions in all circumstances where there is material uncertainty regarding the legal character, enforceability, or regulatory treatment of a transaction, product, or arrangement. Specific requirements include:

- Legal opinions shall be obtained from qualified external counsel where the opinion concerns a matter of foreign law or where the General Counsel determines that external expertise is required.
- All material legal opinions shall be maintained on file and shall be subject to review at the time of the related contract renewal or in response to material changes in applicable law.
- Legal opinions obtained to support capital, liquidity, or netting positions shall satisfy the requirements of applicable prudential regulations.

12.4.4 Litigation Management

The General Counsel is responsible for the active management of all litigation, arbitration, regulatory proceedings, and material disputes involving Stratum Capital Bank. The litigation management framework requires:

- Maintenance of a Litigation Register recording all current and threatened legal proceedings, arbitrations, and regulatory investigations.
- Quarterly reporting to the Board Audit Committee and the Board Risk & Compliance Committee on the status of all material proceedings and associated financial provisioning.

- Engagement of external legal counsel with appropriate expertise for all significant proceedings.
- Co-ordination with the Finance function to ensure that appropriate legal provisions and contingent liabilities are recognised in the Bank's financial statements in accordance with applicable accounting standards.

12.4.5 Legal Documentation Standards

All legal documentation produced by or on behalf of Stratum Capital Bank shall meet the following minimum standards:

- **Completeness:** All material terms, conditions, and obligations shall be stated with sufficient clarity to be unambiguously enforceable.
- **Accuracy:** All representations, warranties, and factual statements shall be accurate and verified at the time of execution.
- **Authenticity:** All executed documents shall be subject to an execution verification process to confirm the authority of signatories.
- **Retention:** All executed legal documents shall be retained in accordance with the Records Management standards set out in Section 12.14 of this Chapter.

12.4.6 Cross-Border Legal Requirements

Given the international scope of Stratum Capital Bank's operations, the Legal Governance framework addresses cross-border legal requirements through the following measures:

- Maintenance of a Jurisdictional Legal Matrix, updated annually, which identifies the applicable legal framework in each operating jurisdiction and highlights material cross-border legal considerations.
- Engagement of qualified local legal counsel in each operating jurisdiction to provide authoritative advice on local law requirements.
- Assessment and management of applicable law conflicts, regulatory arbitrage considerations, and extra-territorial regulatory applications.

12.4.7 Customer Agreements

All customer agreements of Stratum Capital Bank shall comply with the following requirements:

- Terms and conditions shall be expressed in plain, clear, and unambiguous language that is accessible to the intended customer.
- Customer agreements shall be reviewed for compliance with applicable consumer protection, conduct of business, and disclosure requirements prior to deployment.
- Material amendments to customer terms shall be communicated to affected customers with the notice period required by applicable law and regulation.
- All customer agreement templates shall be maintained in a central repository and subject to annual review by Legal and Compliance.

12.5 Corporate Ethics Framework

The Corporate Ethics Framework establishes the ethical standards, behavioural expectations, and governance arrangements that govern the conduct of all individuals associated with Stratum Capital Bank.

The framework is grounded in the ISO 37001:2016 (Anti-Bribery Management Systems), the OECD Anti-Bribery Convention, and the Bank's core values of integrity, professionalism, and accountability. The framework applies without exception to all employees, contractors, consultants, agents, and third parties acting on behalf of the Bank.

12.5.1 Code of Conduct

Stratum Capital Bank's Code of Conduct (SCB-COD-001) is the primary statement of the Bank's ethical expectations. The Code of Conduct is approved by the Board of Directors and applies to all personnel. Key provisions of the Code of Conduct include:

- All individuals must act honestly, transparently, and with integrity in all professional dealings and relationships.
- All individuals must comply at all times with applicable laws, regulations, and internal policies.
- All individuals must treat customers, colleagues, counterparties, and regulators with fairness, respect, and professionalism.
- All individuals must proactively identify and manage potential conflicts of interest in accordance with this Framework.
- All individuals must protect confidential information of the Bank and its customers from unauthorised disclosure or use.
- All individuals must report actual or suspected violations of the Code of Conduct through available reporting channels.

12.5.2 Integrity

The Bank's commitment to integrity requires that all individuals act in an honest, transparent, and trustworthy manner in all circumstances. Integrity obligations include the prohibition of any form of deception, falsification of records, misrepresentation to regulators or customers, and any conduct that could undermine trust in the Bank or in the financial system.

12.5.3 Professional Behaviour

All employees are required to maintain the highest standards of professional behaviour consistent with their role, responsibilities, and the public trust placed in financial institutions. This includes maintaining appropriate professional qualifications where required, treating all parties with respect, and preserving the reputation of the Bank in all external dealings.

12.5.4 Conflict of Interest

A conflict of interest arises when an individual's personal, financial, or professional interests have the potential to interfere with their ability to act in the best interests of the Bank or its customers. The Bank's Conflict of Interest Policy requires:

- All employees to proactively identify and disclose actual, potential, or perceived conflicts of interest to their line manager and to the Compliance function.
- Conflicts of interest to be recorded in the Bank's Conflict of Interest Register and managed through appropriate mitigation measures, including recusal, information barriers, or, where necessary, divestment.
- The Compliance function to maintain oversight of the Conflict of Interest Register and to report material conflicts to the Board Risk & Compliance Committee on a quarterly basis.

12.5.5 Outside Employment

All employees are required to obtain prior written approval from the Human Resources function and the Compliance function before accepting any form of outside employment, directorship, consultancy, or similar engagement. Outside employment approvals shall be reviewed on an annual basis. Employees shall be prohibited from accepting outside engagements that create actual or material conflicts of interest, undermine their primary obligations to the Bank, or involve competitors of the Bank.

12.5.6 Political Activities

Employees of Stratum Capital Bank are prohibited from making any political contributions, donations, or other forms of support on behalf of the Bank without the express prior written approval of the CCO and the Board. Personal political activities by employees shall not be carried out in any manner that could associate the Bank with a political position or create a reputational risk. All political activities or contributions, whether personal or institutional, shall be disclosed to the Compliance function.

12.5.7 Personal Investments

All employees in designated roles are subject to the Bank's Personal Investment Policy, which requires:

- Pre-clearance of personal securities transactions in designated instruments from the Compliance function.
- Blackout period restrictions preventing trading in the Bank's own securities or the securities of material counterparties during restricted periods.
- Annual disclosure of personal investment holdings in designated categories to the Compliance function.
- Prohibition on the use of material non-public information in personal investment decisions.

12.5.8 Gift & Hospitality Policy

The Bank's Gift & Hospitality Policy establishes the standards for the giving and receiving of gifts, entertainment, hospitality, and other benefits. The policy requirements include:

- Gifts received with a value exceeding the prescribed threshold of USD 150 (or local equivalent) per occasion must be declined or surrendered to the Compliance function.
- All gifts given or received with a value above USD 50 must be recorded in the Bank's Gifts & Hospitality Register.
- Business entertainment offered to external parties must receive prior approval from a line manager above the employee's grade.
- No gift, hospitality, or benefit of any nature may be given to a government official, public official, or regulatory authority without the prior written approval of the CCO and the General Counsel.
- Cash gifts are prohibited in all circumstances, irrespective of value.

12.5.9 Anti-Bribery

Stratum Capital Bank maintains a zero-tolerance policy towards bribery in all its forms, consistent with ISO 37001:2016 and the requirements of applicable anti-bribery legislation in all operating jurisdictions. The anti-bribery framework requires:

- The prohibition of any payment, offer, solicitation, or receipt of a bribe, whether by employees, contractors, or third parties acting on the Bank's behalf.

- Enhanced due diligence on high-risk third parties, including agents, intermediaries, and distribution partners, to assess bribery risk prior to engagement.
- Mandatory anti-bribery training for all employees, with enhanced training for employees in higher-risk roles or jurisdictions.
- Specific pre-approval requirements for facilitation payments, which are prohibited in principle but may in very limited circumstances arise under duress — all such instances must be immediately reported to the CCO.

12.5.10 Anti-Corruption

The Bank's anti-corruption framework supplements the anti-bribery policy and extends to all forms of corruption, including fraud, embezzlement, extortion, abuse of power, and the misappropriation of assets. All employees have a duty to report suspected corruption through the whistleblower reporting channels described in Section 12.12 of this Chapter.

12.5.11 Whistleblower Protection

Stratum Capital Bank unconditionally protects all individuals who make a good-faith report of an actual or suspected violation of law, regulation, or internal policy through available reporting channels. The principles of whistleblower protection are set out in detail in Section 12.12 of this Chapter. Retaliation against a whistleblower, including dismissal, demotion, harassment, or any adverse treatment, is treated as a serious disciplinary matter and may constitute a criminal offence under applicable law.

12.6 Conduct Risk Management

Conduct risk is defined as the risk that the Bank's behaviour, the behaviour of its employees, or the design and distribution of its products and services will result in unfair outcomes for customers, market participants, or other stakeholders, or that it will undermine the integrity of financial markets. The Conduct Risk Management framework is consistent with the FCA Conduct Rules, the Senior Managers & Certification Regime (SMCR), and equivalent conduct regulatory standards across all operating jurisdictions.

12.6.1 Customer Fair Treatment

Stratum Capital Bank is unconditionally committed to ensuring fair treatment of all customers at every stage of the customer relationship lifecycle. The Bank's Fair Treatment of Customers (FTC) framework requires that:

- Customers receive products and services that are appropriate to their financial circumstances, needs, and objectives.
- Product and service terms and conditions, fees, and risks are communicated in a manner that is clear, fair, and not misleading.
- Customers are provided with information that enables them to make informed financial decisions.
- Customers in vulnerable circumstances are identified and receive appropriate additional support and accommodation.
- The Bank monitors customer outcomes on an ongoing basis and takes corrective action where outcomes are found to be unfair or inconsistent with regulatory expectations.

12.6.2 Mis-selling Prevention

The Bank operates a comprehensive mis-selling prevention framework, which includes product governance standards, sales conduct controls, mandatory disclosure requirements, suitability assessment processes, and sales monitoring. All products must pass through the Product Approval Process (PAP) before being offered to customers (see Chapter 3 of this Framework for credit product governance and Chapter 7 for operational controls).

12.6.3 Sales Conduct

All sales activities must be conducted in a manner consistent with the Bank's Sales Conduct Policy. Specifically:

- Sales incentives and targets shall not be structured in a manner that creates an undue incentive to sell inappropriate products or to prioritise sales volume over customer suitability.
- All customer interactions in the sales process shall be conducted by appropriately qualified and authorised personnel.
- Sales processes shall include appropriate needs assessment, suitability determination, and documentation at each stage.

12.6.4 Complaint Handling

The Bank operates a structured Complaint Handling Framework, consistent with applicable regulatory requirements. The framework requires:

- All customer complaints to be acknowledged, recorded, and investigated promptly.
- Root cause analysis to be performed on all material complaint categories to identify systemic issues and implement corrective actions.
- Regular reporting of complaint data and trends to the Board Risk & Compliance Committee as a conduct risk indicator.
- Timely resolution and appropriate redress where complaints are upheld.

12.6.5 Employee Conduct

All employees are required to conduct themselves at all times in a manner consistent with the Bank's values, the Code of Conduct, and applicable regulatory conduct rules. Employee conduct expectations are embedded in performance management frameworks, disciplinary policies, and mandatory training programmes.

12.6.6 Manager Accountability

All managers within Stratum Capital Bank bear personal accountability for the conduct of the individuals within their span of responsibility. Manager accountability obligations include:

- Setting clear conduct expectations for direct reports and embedding conduct considerations in performance appraisal processes.
- Promptly identifying and addressing conduct concerns within their teams.
- Escalating material conduct issues to the Compliance function without delay.
- Completing mandatory manager conduct training on an annual basis.

12.6.7 Market Conduct

Stratum Capital Bank is committed to maintaining the highest standards of market conduct in all financial markets in which it operates. The Bank's Market Conduct framework incorporates:

- Strict prohibition of market manipulation, front-running, spoofing, insider trading, and any other form of market abuse.
- Operation of information barrier arrangements to prevent the improper transmission of inside information between the Bank's advisory and dealing functions.
- Adherence to the FX Global Code, the Fixed Income, Currencies and Commodities (FICC) Market Standards, and applicable market codes in all relevant markets.
- Surveillance of trading activity to detect and investigate potential instances of market misconduct.

12.6.8 Ethical Decision Making

The Bank provides all employees with structured guidance on ethical decision making, including a formal Ethical Decision-Making Framework (EDMF). The EDMF requires employees to apply the following considerations when faced with an ethical dilemma:

- Is the proposed action legal under all applicable laws?
- Is the proposed action consistent with the Bank's Code of Conduct, policies, and values?
- Would the proposed action result in fair treatment for all affected parties, including customers and other stakeholders?
- Would the employee be comfortable if the proposed action were disclosed publicly or reported to a regulator?
- If in doubt, stop, seek guidance from the Compliance function, and do not proceed until clarity is obtained.

12.7 Regulatory Reporting

Regulatory reporting encompasses all internal and external reports generated by Stratum Capital Bank in fulfilment of its obligations to the Board, management, and external regulatory authorities. The regulatory reporting framework ensures the accuracy, completeness, timeliness, and integrity of all required reports.

12.7.1 Board Reporting

The Board Risk & Compliance Committee shall receive, on a quarterly basis at minimum, a comprehensive Compliance Risk Report comprising the following:

- Enterprise compliance risk profile, including key risk indicators and trend analysis.
- Summary of all identified regulatory breaches, remediation status, and regulatory notifications made during the reporting period.
- Material regulatory developments and the Bank's preparedness for upcoming regulatory changes.
- Results of material compliance monitoring activities and thematic reviews.
- AML and financial crime risk indicators and escalations.
- Conduct risk indicators, complaint trends, and customer outcomes data.
- Status of the mandatory compliance training programme.

12.7.2 Executive Reporting

The Executive Compliance Committee shall receive monthly compliance management information, including compliance breach notifications, regulatory filing status, emerging risk assessments, and compliance monitoring outcomes. The CCO shall present to the full Executive Committee on a quarterly basis.

12.7.3 Regulatory Filings

All regulatory filings and submissions required by competent regulatory authorities shall be managed through a centralised Regulatory Filing Calendar. The filing calendar shall record all required submissions, applicable deadlines, responsible owners, review and approval requirements, and submission confirmation records. Material regulatory filings shall be reviewed by the CCO and the General Counsel prior to submission.

12.7.4 Incident Reporting

All operational and compliance incidents with actual or potential regulatory significance shall be reported through the Bank's Incident Management system (see Chapter 6 of this Framework) and shall trigger an assessment of regulatory notification obligations. The Compliance function shall maintain oversight of the incident reporting process to ensure material incidents are appropriately escalated and reported.

12.7.5 Breach Reporting

Regulatory breach reporting obligations are set out in detail in Section 12.11 of this Chapter. All material regulatory breaches shall be subject to the formal Regulatory Breach Management process, including external notification to regulators within the timeframes prescribed by applicable regulation.

12.7.6 AI Governance Reporting

Consistent with the AI Governance framework established in Chapter 9 of this Framework, the Compliance function shall include AI governance risk and control indicators in quarterly Board reporting. Specific AI compliance reporting shall include:

- Model risk and AI system performance indicators.
- Compliance with applicable AI regulatory requirements, including any algorithmic transparency or explainability obligations.
- Status of AI system audits and outcomes of model validation reviews.
- Material incidents involving AI systems, including any instances of biased, erroneous, or non-compliant AI outputs.

12.7.7 AML Reporting

Anti-money laundering reporting shall include Suspicious Activity Report (SAR) volumes and trends, customer due diligence (CDD) completion rates, high-risk customer and correspondent banking relationship reviews, and regulatory AML examination preparation status. AML reporting shall be presented to the Board Risk & Compliance Committee quarterly and shall be integrated with the enterprise Financial Crime Risk Assessment.

12.7.8 Operational Risk Reporting

Compliance-related operational risk data, including compliance risk event losses, near-miss incidents, and regulatory fine provisions, shall be integrated into the enterprise operational risk reporting framework as described in Chapter 6 of this Framework, and shall be reported to the Board Risk Committee within the enterprise Risk Management Information (RMI) Report.

12.8 Compliance Monitoring

The Compliance Monitoring framework provides the Compliance function with the systematic means to assess the ongoing adequacy and effectiveness of the controls and processes implemented to manage compliance risk. The monitoring framework is designed in accordance with the Basel Committee Compliance Principles and the COSO Internal Control Framework (Control Activities and Monitoring Activities components).

12.8.1 Monitoring Programme

The annual Compliance Monitoring Programme (CMP) is developed by the CCO and approved by the Board Risk & Compliance Committee on an annual basis. The CMP is a risk-based programme that prioritises monitoring activities on the basis of the enterprise Compliance Risk Assessment. The CMP shall define:

- The scope of each monitoring activity, specifying the business line, process, regulation, and/or product under review.
- The methodology to be applied, including sampling approaches, testing protocols, and evaluation criteria.
- The responsible Compliance Officer and the planned execution timeline.
- The reporting and escalation requirements applicable to the outcome of each activity.

12.8.2 Compliance Testing

Compliance testing encompasses transaction testing, process walkthroughs, system interrogations, and documentary reviews designed to evaluate whether controls are operating effectively and in accordance with applicable regulatory requirements. Testing activities shall be documented, with findings recorded in the Compliance Monitoring system. Material findings shall be escalated to the relevant business unit management and the CCO, and shall trigger a remediation process with defined timelines and accountabilities.

12.8.3 Thematic Reviews

The Compliance function conducts thematic reviews of compliance risk topics that represent material or emerging areas of concern. Thematic reviews may be initiated in response to regulatory publications, enforcement actions against peer institutions, internal risk assessment outputs, or management and Board direction. Findings and recommendations from thematic reviews shall be reported to the Board Risk & Compliance Committee and shall inform updates to the Compliance Risk Inventory and Monitoring Programme.

12.8.4 Continuous Monitoring

In addition to periodic testing and thematic reviews, the Compliance function operates continuous monitoring capabilities, including automated regulatory surveillance systems, transaction monitoring controls (for AML and market abuse purposes), and data analytics tools. Continuous monitoring outputs shall be reviewed on a defined cycle and shall feed into the Compliance Risk Report.

12.8.5 Risk Indicators

The Compliance function maintains a suite of Key Compliance Risk Indicators (KCRIs), approved by the Board Risk & Compliance Committee, that provide forward-looking and current signals of compliance risk levels across the enterprise. KCRIs shall include:

- Number of overdue regulatory filings.
- Number and value of regulatory fines and penalties.
- Rate of overdue mandatory compliance training completion.
- Number of compliance breaches by severity classification.
- AML suspicious activity report volumes and escalation rates.
- Customer complaint volumes and upheld rates by product category.

12.8.6 Compliance Dashboards

Compliance management information shall be presented in a structured Compliance Dashboard that provides timely, visual, and actionable information to the CCO, the Executive Committee, and the Board Risk & Compliance Committee. The Compliance Dashboard shall be produced monthly for management and quarterly for Board-level reporting.

12.8.7 Management Information

All compliance management information shall comply with the following quality standards:

- Accuracy: Information must be based on verified data and identified sources.
- Completeness: All material compliance metrics must be included without omission.
- Timeliness: Information must be produced and distributed within defined timelines.
- Clarity: Information must be presented in a manner that is accessible and actionable to the intended audience.
- Consistency: Definitions, methodologies, and categorisation approaches must be applied consistently across reporting periods.

12.9 Policy Governance

The Policy Governance framework governs the lifecycle of all policies forming part of the Enterprise Governance & Risk Framework and all other regulatory compliance and ethics policies of Stratum Capital Bank. Effective policy governance is fundamental to the Bank's ability to demonstrate that its operations are conducted within a sound, documented, and consistently applied framework of rules and standards.

12.9.1 Policy Creation

All new policies shall be initiated in response to a regulatory requirement, a risk assessment finding, a Board or management directive, or the identification of a governance gap. The policy creation process shall require:

- A Policy Initiation Request, specifying the regulatory or governance basis for the policy.
- Designation of a Policy Owner and a Policy Author.
- Drafting of the policy in accordance with the SCB Policy Writing Standards (SCB-POL-STD-001).
- Stakeholder consultation with all affected business lines, functions, and jurisdictions.
- Legal and Compliance review and sign-off prior to approval.

12.9.2 Policy Approval

Policy approval authorities are tiered in accordance with the Policy Approval Matrix (Appendix D of this Chapter). Enterprise-level policies, including all chapters of the Enterprise Governance & Risk Framework, require Board approval. Divisional policies require approval from the relevant Senior Management Committee. Operational procedures require approval from the relevant business unit head. No policy shall take effect prior to formal approval at the appropriate level.

12.9.3 Version Control

All policies shall be maintained under a formal version control system. Each version of a policy shall carry a unique version number, an effective date, the name of the approving authority, and a summary of changes from the previous version. Version control shall be managed through the Bank's Document Management System (DMS) and access permissions shall be maintained to prevent unauthorised amendment of approved policy documents.

12.9.4 Review Cycle

All policies shall be subject to a formal review on an annual basis, or more frequently in response to material regulatory changes, significant risk events, internal audit findings, or Board or management direction. The annual Policy Review Schedule (Appendix E of this Chapter) shall be maintained by the Head of Compliance Policy & Governance and shall be reported to the Board Risk & Compliance Committee.

12.9.5 Document Ownership

Each policy shall have a designated Document Owner, who is accountable for the currency, accuracy, and completeness of the policy. Document ownership shall be assigned to a named individual at a level appropriate to the scope and significance of the policy. Document Owners shall ensure that their policies are reviewed within the prescribed review cycle and shall be accountable for the quality of the policy content.

12.9.6 Policy Exceptions

Where a business activity cannot be conducted in strict compliance with an applicable policy, a formal Policy Exception may be requested. The Policy Exception process requires:

- Submission of a Policy Exception Request, detailing the nature of the exception, the business rationale, the risks associated with the exception, and the proposed compensating controls.
- Review and approval by the CCO for Compliance policies and the CRO for Risk policies.
- Board Risk & Compliance Committee approval for material exceptions to enterprise-level policies.

- Time-limitation of all exceptions to a maximum period of twelve months, subject to renewal following the same approval process.
- Recording of all approved exceptions in the Policy Exception Register.

12.9.7 Policy Retirement

Policies that are no longer applicable, have been superseded, or whose regulatory basis has been repealed shall be formally retired through the Policy Retirement Process. Retired policies shall be archived in the Document Management System and shall remain accessible for audit and regulatory purposes for the duration of the applicable document retention period.

12.9.8 Cross References

All policies shall include cross-references to related documents, including other policies, procedures, regulatory requirements, and system controls. The maintenance of an accurate and complete policy cross-reference framework is the responsibility of the Policy Custodian and shall be reviewed as part of the annual Policy Review cycle.

12.10 Training & Awareness

Training and awareness are fundamental components of the compliance culture of Stratum Capital Bank. An effective training and awareness programme ensures that all employees maintain the knowledge and understanding necessary to fulfil their individual compliance obligations and to contribute to the Bank's overall compliance posture. The Bank's training framework is consistent with ISO 37301:2021 requirements for compliance competence and awareness.

12.10.1 Mandatory Compliance Training

All employees of Stratum Capital Bank are required to complete a defined suite of mandatory compliance training modules. Mandatory training completions are tracked through the Bank's Learning Management System (LMS). Non-completion of mandatory training is an escalatable compliance matter and will be reported to the relevant line manager and, for persistent non-completion, to Human Resources for appropriate action. The mandatory training suite comprises all modules set out in Sections 12.10.2 through 12.10.8 below.

12.10.2 Annual Certification

All employees must annually certify, in writing, their understanding of and compliance with the Bank's Code of Conduct, the Enterprise Governance & Risk Framework, and all applicable mandatory policies. Annual certification shall be completed through the LMS and records shall be retained for a minimum of seven years. Non-completion of the annual certification is treated as a disciplinary matter.

12.10.3 Ethics Training

Annual ethics training is mandatory for all employees. The ethics training programme covers the Code of Conduct, conflict of interest management, gift and hospitality policy, anti-bribery and anti-corruption

requirements, and ethical decision-making. Enhanced ethics training, incorporating role-specific scenarios, is required for employees in senior or client-facing positions.

12.10.4 AI Governance Training

All employees engaged in the design, development, deployment, or oversight of AI systems are required to complete the Bank's AI Governance Training Programme, consistent with the AI Governance framework established in Chapter 9 of this Framework. The AI Governance Training Programme covers:

- Applicable regulatory requirements for AI and algorithmic systems in financial services.
- The Bank's AI Risk Management framework and AI Model Governance Standards.
- Ethical principles in AI, including fairness, explainability, and accountability.
- Incident reporting obligations for AI-related failures and anomalies.

12.10.5 AML Training

Anti-money laundering training is mandatory for all employees, with enhanced training required for employees in client-facing, onboarding, transaction processing, and compliance roles. The AML training programme is reviewed and updated annually to reflect changes in the threat environment, regulatory guidance, and internal risk assessments. Training content shall cover the Bank's Customer Due Diligence (CDD) requirements, suspicious activity identification and reporting, sanctions screening, and the consequences of AML policy non-compliance.

12.10.6 Cyber Security Training

Annual cyber security awareness training is mandatory for all employees, consistent with the Cyber Security framework established in Chapter 10 of this Framework. Training content shall cover phishing and social engineering awareness, data protection obligations, secure information handling, and incident reporting procedures.

12.10.7 Fraud Awareness

All employees are required to complete annual fraud awareness training covering internal and external fraud typologies, red flag indicators, control responsibilities, and fraud reporting procedures, consistent with the Fraud Governance framework established in Chapter 5 of this Framework.

12.10.8 Manager Responsibilities

All managers within Stratum Capital Bank bear specific accountability for the training and compliance awareness of their direct reports. Managers are responsible for:

- Monitoring compliance training completion rates within their teams and taking prompt action to address non-completion.
- Integrating compliance and conduct considerations into team meetings, performance discussions, and coaching sessions.
- Leading by example in demonstrating a compliance-first culture and ethical behaviour.
- Completing enhanced manager-specific compliance and conduct training on an annual basis.

12.11 Regulatory Breach Management

The Regulatory Breach Management framework sets out the structured process through which Stratum Capital Bank identifies, escalates, assesses, investigates, remediates, and reports all actual or suspected regulatory breaches. Effective breach management is a core component of the Bank's regulatory relationships and is fundamental to the supervisory expectation of an open and transparent engagement with regulators.

12.11.1 Identification

Regulatory breaches may be identified through multiple channels, including self-identification by business unit employees, compliance monitoring activities, Internal Audit findings, customer complaints, whistleblower reports, or regulatory examination findings. All employees have an obligation to report actual or suspected regulatory breaches to the Compliance function immediately upon identification.

12.11.2 Escalation

Upon identification of an actual or suspected regulatory breach, the following escalation framework shall apply:

- Immediate notification to the relevant Compliance Officer and line management.
- Compliance Officer to notify the CCO within 24 hours of identification of any breach that may be material.
- CCO to notify the CRO and the General Counsel immediately upon identification of a material breach.
- CCO to notify the Board Risk & Compliance Committee Chair and the CEO within 48 hours of identification of any material breach that may require regulatory notification.

12.11.3 Materiality Assessment

Upon escalation, the Compliance function shall conduct a formal Materiality Assessment of the identified breach. The materiality assessment shall consider:

- The nature of the regulatory obligation breached.
- The duration of the breach and the period of non-compliance.
- The financial impact, including any actual or potential customer detriment.
- The reputational impact of the breach and potential for adverse media or regulatory attention.
- Whether the breach is isolated or indicative of a systemic control failure.
- The applicable regulatory notification thresholds and timelines.

12.11.4 Root Cause Analysis

All material regulatory breaches shall be subject to a formal Root Cause Analysis (RCA) within 30 business days of identification. The RCA shall be conducted by the Compliance function, with input from the relevant business unit and, where required, external subject matter experts. The RCA shall identify the immediate cause, contributing factors, and underlying root causes of the breach, and shall form the basis for the development of corrective actions.

12.11.5 Corrective Actions

Based on the Root Cause Analysis, the Compliance function and the relevant business unit shall develop a formal Corrective Action Plan (CAP) specifying remediation activities, accountable owners, and completion timelines. The CAP shall be approved by the CCO and, for material breaches, by the Board Risk & Compliance Committee. Progress against the CAP shall be tracked and reported monthly until all actions are verified as complete.

12.11.6 Regulatory Notification

Where a breach meets the notification threshold of an applicable regulatory authority, the CCO and the General Counsel shall manage the preparation and submission of the regulatory notification. Regulatory notifications shall be:

- Accurate, complete, and not misleading in any material respect.
- Delivered within the notification timeframe prescribed by applicable law or regulation, or sooner where practicable.
- Reviewed and approved by the CEO and, where the breach is of Board significance, by the Chair of the Board Risk & Compliance Committee, prior to submission.

12.11.7 Board Notification

The CCO shall notify the full Board of Directors of any regulatory breach that is material by reference to the criteria set out in Section 12.11.3, at the next scheduled Board meeting or by extraordinary written communication, whichever is earlier. Board notification shall include a summary of the breach, its cause, impact, remediation status, and regulatory notification status.

12.11.8 Lessons Learned

Upon the closure of a material regulatory breach, the Compliance function shall conduct a formal Lessons Learned review. The output of the Lessons Learned review shall be shared with the Board Risk & Compliance Committee, the relevant business unit management, and other affected areas of the Bank. Lessons Learned shall inform updates to policies, controls, training programmes, and monitoring activities to reduce the risk of recurrence.

12.12 Whistleblowing Programme

Stratum Capital Bank's Whistleblowing Programme is a critical element of the Bank's corporate ethics framework and regulatory compliance posture. The Programme provides employees, contractors, customers, and external parties with safe, confidential, and effective channels through which to report actual or suspected violations of law, regulation, or internal policy. The Programme is consistent with the requirements of applicable whistleblowing legislation across all operating jurisdictions and reflects the Bank's commitment to transparency and accountability.

12.12.1 Anonymous Reporting

The Bank operates a dedicated independent whistleblowing hotline (SCB Speak-Up Line) managed by an independent third-party service provider. The Speak-Up Line is available 24 hours per day, seven days per week, and supports anonymous reporting in all languages of the Bank's operating jurisdictions. The Speak-Up Line is the primary mechanism for the submission of sensitive whistleblowing reports. Additional

reporting channels include a dedicated compliance email address and direct access to the CCO or Independent Non-Executive Directors.

12.12.2 Investigation

All reports received through the whistleblowing programme shall be subject to an initial triage assessment within five business days of receipt. Reports that allege material violations of law or regulation, financial crime, fraud, senior management misconduct, or market abuse shall be classified as Priority Investigations and assigned to a senior Compliance Officer. Investigations shall be conducted:

- Promptly and with appropriate resources.
- By investigators who are independent of the subject of the report.
- In accordance with the Bank's Investigation Standards and applicable employment law requirements.
- With appropriate confidentiality protections for the reporting individual and all persons involved.

12.12.3 Confidentiality

The identity of any individual who makes a whistleblowing report shall be treated as strictly confidential and shall not be disclosed, except to the extent required by applicable law or with the explicit consent of the reporting individual. Disclosure of a whistleblower's identity without authorisation is a serious disciplinary offence. All information relating to whistleblowing reports and investigations shall be maintained in a secure, access-controlled environment.

12.12.4 Protection Against Retaliation

Stratum Capital Bank unconditionally prohibits retaliation, victimisation, or adverse treatment of any individual who makes or is suspected of making a good-faith whistleblowing report. Prohibited retaliatory conduct includes, without limitation, dismissal, demotion, reduction in compensation, exclusion from activities, harassment, bullying, and any form of adverse employment consequence connected to a whistleblowing report. Any manager or employee found to have engaged in retaliatory conduct shall be subject to disciplinary proceedings, up to and including dismissal.

12.12.5 Case Management

All whistleblowing reports shall be recorded and managed through the Bank's Whistleblowing Case Management System. The system shall maintain a complete and auditable record of each report, the triage assessment, the investigation activities, the findings, the outcome, and any corrective actions taken. Access to the system shall be restricted to the CCO, the Head of Whistleblowing Investigations, and designated senior compliance personnel.

12.12.6 Reporting Requirements

The CCO shall report to the Board Audit Committee and the Board Risk & Compliance Committee on a quarterly basis on the following metrics:

- Total volume of reports received, by channel and subject matter category.
- Number of reports subject to formal investigation and investigation outcomes.
- Number of reports escalated to regulators or law enforcement agencies.
- Any instances of alleged retaliation and the outcomes of related disciplinary proceedings.

- Timeliness of investigation closure relative to established standards.

12.12.7 Audit Oversight

Internal Audit shall conduct an annual independent review of the effectiveness of the Whistleblowing Programme, including the independence and quality of investigations, the adequacy of confidentiality protections, the effectiveness of anti-retaliation measures, and the completeness and accuracy of case management records. The findings of this review shall be reported to the Board Audit Committee.

12.13 Third Party Compliance

Stratum Capital Bank recognises that it may be exposed to compliance, financial crime, and reputational risks through its relationships with third parties, including vendors, service providers, outsourcing partners, agents, distributors, and correspondents. The Third Party Compliance framework ensures that all material third-party relationships are subject to appropriate risk assessment, due diligence, contractual controls, and ongoing monitoring, consistent with the Basel Committee's Principles for the Sound Management of Operational Risk, FATF guidance, and the outsourcing governance standards applicable in the Bank's operating jurisdictions.

12.13.1 Vendor Due Diligence

Prior to entering into a material third-party relationship, the Bank shall conduct a compliance due diligence assessment commensurate with the nature, scale, and risk of the proposed relationship. Due diligence shall include:

- Verification of the third party's legal registration, regulatory authorisations, and ownership structure.
- Assessment of the third party's compliance framework, AML controls, sanctions screening procedures, and data protection practices.
- Screening of the third party against applicable sanctions lists, adverse media databases, and politically exposed person registers.
- Review of the third party's financial stability, operational resilience, and business continuity capabilities (see Chapter 11 of this Framework for BCM requirements).
- Enhanced due diligence for high-risk third parties, including those operating in high-risk jurisdictions or providing services that are critical to the Bank's regulatory compliance.

12.13.2 Outsourcing Governance

All material outsourcing arrangements shall be subject to the Bank's Outsourcing Policy, which is consistent with applicable regulatory outsourcing requirements, including those of the Bank's home jurisdiction prudential regulator. Material outsourcing arrangements shall be subject to Board-level approval and shall include contractual provisions addressing service standards, data protection, audit rights, regulatory access, sub-contracting restrictions, and termination procedures. The Bank shall maintain a Material Outsourcing Register, reviewed quarterly by the CCO and CRO.

12.13.3 Third Party Monitoring

The compliance performance of material third parties shall be monitored on an ongoing basis. Monitoring activities shall include:

- Annual compliance performance reviews for all material third parties.
- Regular review of third-party screening outcomes for changes in sanctions, adverse media, or ownership status.
- Assessment of compliance-related incidents, service disruptions, or regulatory actions involving third parties.
- Review of third-party audit reports, certifications, and regulatory correspondence relevant to the Bank's relationship.

12.13.4 Sanctions Screening

All third parties engaged by the Bank shall be screened against applicable sanctions lists maintained by competent authorities, including OFAC, the EU, HMRC, and the UN Security Council, prior to engagement and on a periodic basis thereafter. Positive screening matches shall be escalated to the Compliance function for assessment and, where required, to the CCO and the Board. No new third-party relationship shall be established with a sanctioned entity.

12.13.5 Ongoing Reviews

Material third-party relationships shall be subject to a formal annual compliance review, comprising an updated due diligence assessment, a review of contractual compliance, and an evaluation of the third party's compliance performance during the review period. Reviews shall be documented and retained in accordance with the Records Management standards set out in Section 12.14.

12.13.6 Termination Procedures

Where a third-party relationship is terminated on grounds of compliance failure, reputational concern, or regulatory direction, the termination shall be managed in accordance with the Bank's Third Party Exit Framework. Termination procedures shall address the secure transfer or destruction of data, the management of any regulatory notification obligations, the maintenance of operational continuity during the transition period, and the retention of records relating to the terminated relationship.

12.14 Records Management

Effective records management is a fundamental regulatory obligation and a prerequisite for the Bank's ability to demonstrate compliance with applicable laws and regulations. The Records Management framework governs the creation, storage, protection, retention, retrieval, and destruction of all records generated in the course of the Bank's operations, consistent with the requirements of applicable law, regulation, and the COSO Internal Control Framework.

12.14.1 Document Retention

All records of Stratum Capital Bank shall be retained for the minimum period prescribed by applicable law, regulation, or supervisory requirement, or for such longer period as may be required by the Records Retention Schedule maintained by the Head of Compliance Policy & Governance. The minimum retention periods for key record categories are:

Record Category	Minimum Retention Period
Accounting and financial records	7 years from the date of the record
Customer onboarding and CDD records	5 years from the end of the customer relationship (10 years where directed by regulation)
Transaction records (regulated products)	7 years from the date of the transaction
Regulatory correspondence and filings	7 years from the date of correspondence
Legal agreements and contracts	7 years from the expiry or termination of the agreement
Compliance monitoring and testing records	7 years from the date of the activity
Board and Committee minutes	Permanent
Employment records	7 years from the end of employment
Whistleblowing investigation records	10 years from the closure of the investigation
AI Model documentation	Duration of model use plus 7 years

12.14.2 Evidence Standards

All records shall be maintained to a standard that renders them suitable for use as evidence in regulatory proceedings, litigation, or internal investigations. Evidence standards require:

- Records to be accurate, complete, and not altered from the original form without appropriate authorisation and version control.
- Records to be legible and comprehensible to a qualified reviewer with appropriate context.
- Records to be stored in a manner that ensures their accessibility and retrievability throughout the applicable retention period.

12.14.3 Electronic Records

Electronic records shall be stored in approved electronic document management systems that provide appropriate access controls, audit trails, version control, and protection against unauthorised modification or deletion. Employees are prohibited from storing records exclusively on personal devices, unmanaged cloud storage services, or email systems without an appropriate archiving solution.

12.14.4 Legal Hold

Where the Bank becomes aware of actual or anticipated litigation, regulatory investigation, or enforcement action, a Legal Hold notice shall be issued by the General Counsel. A Legal Hold suspends the normal destruction of all records that may be relevant to the subject matter of the hold. Legal Holds shall be managed in the Bank's Legal Hold system and shall be communicated to all relevant custodians. Employees who receive a Legal Hold notice are prohibited from destroying, deleting, or altering any covered records.

12.14.5 Archiving

Records that are no longer in active use but are within their retention period shall be transferred to the Bank's approved archive facilities, whether physical or electronic. Archived records shall be indexed and

catalogued to ensure timely retrievability. Access to archived records shall be restricted to authorised personnel and shall require appropriate justification.

12.14.6 Destruction Policy

Records that have reached the end of their prescribed retention period and are not subject to a Legal Hold shall be destroyed in a secure and irrecoverable manner. Physical records shall be destroyed by an approved secure destruction service. Electronic records shall be purged from all systems and storage media in a manner that prevents recovery. Destruction shall be documented in the Bank's Record Destruction Log. Records may not be destroyed in anticipation of a regulatory inquiry or litigation.

12.14.7 Audit Trails

All material business transactions, approvals, compliance reviews, and control activities shall be supported by a complete and tamper-evident audit trail. Audit trails shall be maintained in approved systems and shall be accessible to the Compliance function, Internal Audit, and regulatory authorities on request. The destruction or modification of audit trail records is a serious disciplinary matter and may constitute a criminal offence.

12.15 Enterprise Governance Integration

This Chapter serves as the overarching governance umbrella for the entirety of the Enterprise Governance & Risk Framework of Stratum Capital Bank. The provisions of this Chapter integrate with, and provide the governance framework for, each of the preceding chapters of the Framework, as set out below.

12.15.1 Relationship to Chapters 1–11

Chapter	Subject	Chapter 12 Governance Integration
Chapter 1	Enterprise Governance Framework	Chapter 12 provides the regulatory compliance and ethics overlay for the Board governance structure, Three Lines of Defence, and governance accountability framework established in Chapter 1.
Chapter 2	Enterprise Risk Management	The Compliance Risk Management framework in Sections 12.3 and 12.8 integrates directly with the enterprise risk taxonomy, RCSA process, and risk appetite framework established in Chapter 2.
Chapter 3	Credit Governance	Chapter 12 provides the regulatory compliance framework governing credit regulatory capital requirements, credit risk regulatory reporting, and customer fair treatment obligations applicable to credit products.
Chapter 4	Treasury & Capital	Chapter 12 provides the compliance framework for prudential regulatory

		reporting, capital adequacy disclosures (Pillar 3), and regulatory capital governance established in Chapter 4.
Chapter 5	Fraud Governance	The Anti-Bribery, Anti-Corruption, and Whistleblowing provisions of Chapter 12 integrate directly with the fraud prevention and detection framework established in Chapter 5.
Chapter 6	Operational Risk	Compliance risks are a sub-category of operational risk. Chapter 12 provides the compliance risk identification, monitoring, and reporting framework that feeds into the enterprise operational risk management programme established in Chapter 6.
Chapter 7	Internal Controls	The COSO-aligned control framework in Chapter 12, including policy governance, monitoring, and testing standards, operates as the governance overlay for the internal control framework established in Chapter 7.
Chapter 8	Data Governance	Chapter 12 provides the regulatory compliance framework for data protection, customer privacy, and regulatory reporting obligations applicable to the data assets governed by Chapter 8.
Chapter 9	AI Governance	Chapter 12 provides the regulatory compliance overlay for AI model governance, AI regulatory reporting, and ethical AI obligations, integrating with the AI Governance framework established in Chapter 9.
Chapter 10	Cyber Security	Chapter 12 provides the regulatory compliance framework for cyber security regulatory obligations, including notification requirements for material cyber incidents, integrating with the Cyber Security framework in Chapter 10.
Chapter 11	Business Continuity	Chapter 12 provides the regulatory compliance and governance standards for operational resilience regulatory requirements, integrating with the Business Continuity Management framework established in Chapter 11.

The Board Risk & Compliance Committee holds governance oversight over all chapters of the Enterprise Governance & Risk Framework. The CCO, CRO, and General Counsel collectively serve as the principal Second Line governance actors for all chapters. Internal Audit provides independent Third Line assurance across the entirety of the Framework.

12.16 Continuous Improvement

Stratum Capital Bank is committed to the continuous improvement of its compliance framework in response to changes in the regulatory environment, the Bank's risk profile, lessons learned from internal and external events, and advances in compliance management practices. Continuous improvement is an embedded principle of ISO 37301:2021 and is fundamental to the effectiveness of the Bank's compliance management system over time.

12.16.1 Regulatory Change Management

The Compliance function shall operate a structured Regulatory Change Management process that ensures all material changes to applicable laws, regulations, and regulatory guidance are identified, assessed for their impact on the Bank's operations, and implemented in a timely and controlled manner. All regulatory change implementations shall be tracked through the Regulatory Change Register and shall be subject to completion confirmation testing by the Compliance function prior to close-out.

12.16.2 Policy Reviews

All policies comprising the Enterprise Governance & Risk Framework are subject to annual review, as set out in the Policy Review Schedule (Appendix E). Reviews shall consider regulatory changes, internal audit findings, compliance monitoring results, breach history, and industry and regulatory best practice developments. Material revisions to any chapter of the Framework shall be presented to the Board Risk & Compliance Committee for approval.

12.16.3 Framework Reviews

The Enterprise Governance & Risk Framework as a whole shall be subject to a comprehensive, end-to-end governance review on a biennial basis. The framework review shall be conducted by the CCO in conjunction with the CRO, the General Counsel, and senior leadership across all governance functions. The outcome of the framework review shall be presented to the full Board of Directors for approval.

12.16.4 Lessons Learned

The Bank shall maintain a formal Lessons Learned repository capturing insights derived from internal compliance breaches, near-misses, external enforcement actions against peer institutions, regulatory thematic reviews, and internal audit findings. Lessons Learned shall be systematically assessed to identify opportunities for improvement in policies, controls, training, and monitoring activities. The Lessons Learned repository shall be reviewed by the Executive Compliance Committee on a quarterly basis.

12.16.5 Emerging Regulations

The Compliance function shall monitor and assess emerging regulatory developments, including proposed legislation, regulatory consultation papers, supervisory guidance, and international standard-setting activities. Emerging regulatory risks and preparedness assessments shall be reported to the Board Risk & Compliance Committee as a standing agenda item. The Bank shall engage constructively in industry consultative processes to contribute to the development of effective regulatory frameworks.

12.16.6 Benchmarking

The CCO shall, on an annual basis, benchmark the Bank's compliance framework against the practices of leading international financial institutions, relevant regulatory guidance, and published industry frameworks.

Benchmarking activities may be supported by engagement with external advisors, participation in industry working groups, or the commissioning of independent external reviews. Material benchmarking findings shall be reported to the Board Risk & Compliance Committee together with proposed improvement initiatives.

12.16.7 Independent Reviews

The Board Risk & Compliance Committee may, at its discretion, commission independent external reviews of any component of the compliance framework. Independent reviews shall be conducted by qualified external experts with the appropriate regulatory and compliance expertise. The Bank shall provide external reviewers with full cooperation, access to relevant records, and access to management and staff as required. Findings and recommendations from independent reviews shall be presented to the Board and shall be tracked to closure.

12.16.8 Continuous Enhancement

The Bank shall invest continuously in the enhancement of its compliance capabilities, including compliance technology, data analytics, automated monitoring tools, and talent development. Enhancement initiatives shall be prioritised in accordance with the enterprise risk assessment and shall be subject to appropriate governance and investment approval processes.

12.17 Framework Ownership

The Enterprise Governance & Risk Framework is a foundational governance document of Stratum Capital Bank. Its ownership, approval, maintenance, and review are subject to the highest levels of corporate governance within the institution.

12.17.1 Board Approval

The Enterprise Governance & Risk Framework, including all chapters and appendices, requires approval by the Board of Directors on an annual basis, following the recommendation of the Board Risk & Compliance Committee. No chapter of the Framework may be amended, superseded, or retired without Board approval. Board approval of the Framework shall be evidenced by formal Board resolution, recorded in the minutes of the relevant Board meeting.

12.17.2 Chief Executive Officer

The Chief Executive Officer is responsible for ensuring that the Enterprise Governance & Risk Framework is implemented effectively across all operations of Stratum Capital Bank. The CEO is accountable to the Board for the overall effectiveness of the governance and compliance framework and for the allocation of adequate resources to the functions that manage and oversee governance and compliance obligations.

12.17.3 Chief Compliance Officer

The Chief Compliance Officer is the Document Owner for Chapter 12 and all compliance-related components of the Framework. The CCO is responsible for the design, maintenance, and annual review of this Chapter and for ensuring that its content remains aligned with applicable regulatory requirements and

governance best practice. The CCO is accountable to the Board Risk & Compliance Committee for the quality and currency of Chapter 12.

12.17.4 Chief Risk Officer

The Chief Risk Officer is the co-sponsor of the Enterprise Governance & Risk Framework and is responsible for ensuring the integration of the compliance framework with the enterprise risk management architecture. The CRO provides review and challenge to the compliance provisions of the Framework on an annual basis.

12.17.5 Policy Custodian

The Head of Compliance Policy & Governance is designated as the Policy Custodian for Chapter 12. The Policy Custodian is responsible for the day-to-day maintenance of the chapter, the management of the version control process, and the coordination of the annual review cycle. The Policy Custodian shall notify the CCO of any material regulatory development that requires an interim update to the Chapter.

12.17.6 Document Custodian

The Document Management function of the Compliance Shared Services team is responsible for the physical and electronic storage, access management, and archiving of the master copy of Chapter 12 and all superseded versions. The Document Custodian shall ensure that the current approved version of the chapter is accessible to all employees through the Bank's intranet and Document Management System.

12.17.7 Annual Certification

The CCO shall certify to the Board Risk & Compliance Committee, on an annual basis, that Chapter 12 has been reviewed, that its content remains appropriate and reflects current regulatory requirements, and that the compliance monitoring activities conducted during the review period demonstrate that the Framework is operating effectively. The certification shall be provided in writing and shall be recorded in the minutes of the Board Risk & Compliance Committee.

12.17.8 Framework Review Process

The annual Framework Review Process shall be initiated by the Policy Custodian no later than 31 October of each year, to ensure that the review, approval, and distribution of the updated Framework can be completed before the 1 January effective date. The review process shall follow the Policy Governance standards set out in Section 12.9 of this Chapter.

12.18 Final Governance Statement

This Section constitutes the Final Governance Statement of the Enterprise Governance & Risk Framework of Stratum Capital Bank. It represents the binding, enterprise-wide expression of the Bank's commitment to regulatory compliance, legal governance, and corporate ethics.

12.18.1 Policy Supremacy Statement

This Chapter, together with all preceding chapters of the Enterprise Governance & Risk Framework, constitutes the supreme policy document of Stratum Capital Bank in matters of governance, risk management, regulatory compliance, legal governance, and corporate ethics. In the event of any conflict between this Chapter and any other internal policy, procedure, or guidance, the provisions of this Chapter shall prevail, without exception, unless the conflicting provision reflects a more stringent regulatory requirement applicable in a specific jurisdiction, in which case the more stringent requirement shall apply.

12.18.2 Entire Framework Applicability

The Enterprise Governance & Risk Framework (Chapters 1 through 12) applies in its entirety to Stratum Capital Bank N.V., all of its wholly-owned and majority-owned subsidiaries, all branches operating in the Bank's name, and all employees, officers, directors, contractors, agents, and other individuals acting on behalf of the Bank in any capacity. No entity, jurisdiction, or individual is exempt from the provisions of this Framework without formal written Board approval. Geographic or jurisdictional variations in the application of specific provisions must be documented, approved, and maintained in the Bank's Jurisdictional Variation Register.

12.18.3 Employee Responsibilities

Every employee of Stratum Capital Bank, regardless of grade, function, or location, is personally responsible for:

- Reading, understanding, and complying with this Chapter and all applicable elements of the Enterprise Governance & Risk Framework.
- Completing all mandatory compliance training and annual certification requirements within the prescribed timelines.
- Reporting actual or suspected violations of applicable law, regulation, or internal policy through available reporting channels without delay.
- Cooperating fully with all compliance monitoring activities, regulatory examinations, and internal investigations.
- Maintaining the confidentiality of the Bank's governance and compliance information as required.

12.18.4 Manager Responsibilities

Every manager within Stratum Capital Bank bears specific personal accountability for:

- Implementing and maintaining the compliance framework within their area of responsibility.
- Ensuring that all direct reports understand and comply with their individual compliance obligations.
- Promptly escalating compliance concerns and breaches through the appropriate governance channels.
- Setting a personal example of ethical conduct and compliance-first behaviour that is consistent with the Bank's values and the provisions of this Framework.
- Ensuring that their teams complete mandatory training and annual certification requirements and tracking non-compliance with training obligations.

12.18.5 Executive Accountability

Members of the Executive Committee are personally and collectively accountable for:

- Championing the compliance culture established by the Board and ensuring it is embedded throughout the organisation.
- Allocating adequate resources, talent, and technology to the governance, risk management, and compliance functions.
- Making timely and accurate regulatory notifications as required, and maintaining an open and cooperative relationship with all regulatory authorities.
- Ensuring that no business objective or commercial consideration is pursued at the expense of the Bank's regulatory obligations or ethical standards.

12.18.6 Board Accountability

The Board of Directors of Stratum Capital Bank bears ultimate and collective accountability for:

- The governance, oversight, and strategic direction of the compliance and ethics framework of the Bank.
- Approving and maintaining the Enterprise Governance & Risk Framework as the foundational governance document of the institution.
- Satisfying itself, through the Board Risk & Compliance Committee and Board Audit Committee, that the compliance framework is effective and that material compliance risks are being appropriately managed.
- Holding management accountable for the effective implementation of the Framework and for addressing identified compliance deficiencies in a timely manner.

12.18.7 Legal Effect

The provisions of this Chapter and the Enterprise Governance & Risk Framework as a whole constitute binding internal governance obligations of Stratum Capital Bank. Violation of the provisions of this Framework may result in disciplinary action, up to and including dismissal, civil or criminal liability, and regulatory sanctions. The Framework does not in any way limit or supersede the obligations imposed by applicable law and regulation, which continue to apply in full.

12.18.8 Regulatory Compliance Commitment

Stratum Capital Bank is irrevocably committed to the principle that all of its activities shall be conducted in full compliance with applicable laws and regulations across all jurisdictions in which it operates. This commitment is not contingent on commercial considerations, business objectives, or competitive pressures. Where regulatory requirements and commercial objectives conflict, regulatory compliance shall prevail. This commitment extends to the spirit, as well as the letter, of applicable regulatory requirements.

12.18.9 Framework Effectiveness Statement

Based on the compliance monitoring activities, independent internal audit assessments, and management attestations reviewed during the annual certification process, the Chief Compliance Officer hereby certifies that, as at the Effective Date of this Chapter:

- The Enterprise Governance & Risk Framework establishes a comprehensive and robust governance structure appropriate for an institution of the systemic significance of Stratum Capital Bank.
- The compliance framework, as designed, is capable of meeting the Bank's regulatory compliance obligations across all material operating jurisdictions.

- The compliance monitoring and testing programme has been conducted in accordance with the requirements of this Chapter during the prior review period.
- Material compliance deficiencies identified during the review period are subject to documented remediation plans with appropriate accountabilities and timelines.

12.18.10 Future Amendments

This Chapter shall be amended as required to reflect material changes in applicable law, regulation, or supervisory guidance; material changes in the Bank's operations, risk profile, or business model; the findings of independent reviews or regulatory examinations; or Board direction. All amendments shall be subject to the Policy Governance standards set out in Section 12.9 and shall require Board approval prior to taking effect. Amendment requests may be submitted to the Policy Custodian by any member of the Executive Committee, the General Counsel, or the Head of Compliance Policy & Governance.

— END OF CHAPTER 12 —

Enterprise Governance & Risk Framework | Chapter 12 | Version 5.4.1 | Effective 1 January 2025

CONFIDENTIAL — INTERNAL USE ONLY | Stratum Capital Bank N.V.

APPENDIX A — GOVERNANCE DEFINITIONS

For the purposes of this Chapter and the Enterprise Governance & Risk Framework, the following definitions apply:

Term	Definition
Anti-Bribery	The prohibition on offering, giving, receiving, or soliciting any item of value for the purpose of influencing or inducing a public official or private party to act or refrain from acting in the discharge of their duties.
Breach	Any instance of actual non-compliance with an applicable law, regulation, internal policy, or supervisory requirement.
Chief Compliance Officer (CCO)	The Senior Executive holding designated responsibility for the oversight and management of the enterprise compliance framework.
Code of Conduct	The primary statement of the ethical standards and behavioural expectations of Stratum Capital Bank, approved by the Board.
Compliance Function	The organisational unit(s) headed by the CCO responsible for compliance risk oversight, advisory services, monitoring, and reporting.
Compliance Risk	The risk of legal or regulatory sanctions, material financial loss, or reputational damage arising from failure to comply with applicable laws, regulations, or supervisory requirements.
Conduct Risk	The risk that the behaviour of the Bank or its employees will result in unfair outcomes for customers, clients, or market integrity.
Conflict of Interest	A situation in which an individual's personal, financial, or professional interests may compromise or appear to compromise their ability to act in the best interests of the Bank or its customers.

Corrective Action Plan (CAP)	A formal, documented plan for the remediation of identified compliance deficiencies, specifying activities, owners, and timelines.
Enterprise Governance & Risk Framework	The integrated governance document comprising Chapters 1 through 12, approved by the Board of Directors.
G-SIB	Globally Systemically Important Bank, as designated by the Financial Stability Board.
Key Compliance Risk Indicator (KCRI)	A quantitative or qualitative metric used to monitor the level or trend of compliance risk exposure.
Legal Hold	An instruction issued by the General Counsel to suspend the normal destruction of records that may be relevant to litigation, regulatory investigation, or enforcement proceedings.
Materiality	The threshold at which a compliance breach or risk exposure is sufficiently significant to require escalation to senior management, the Board, or a regulatory authority.
Policy Exception	A formally approved deviation from a Bank policy, subject to defined compensating controls and time limitations.
Regulatory Breach	A compliance breach involving a failure to meet an obligation imposed by applicable law, regulation, or supervisory requirement.
Root Cause Analysis (RCA)	A structured investigation methodology to identify the fundamental cause(s) of a compliance breach or incident.
Three Lines of Defence	A governance model allocating accountability for risk management: First Line (business units), Second Line (risk and compliance functions), Third Line (internal audit).
Whistleblowing	The act of reporting, in good faith, an actual or suspected violation of law, regulation, or internal policy through an available reporting channel.

APPENDIX B — ACRONYMS

Acronym	Full Form
AML	Anti-Money Laundering
ALCO	Asset & Liability Committee
BCM	Business Continuity Management
BCBS	Basel Committee on Banking Supervision
CAP	Corrective Action Plan
CDD	Customer Due Diligence
CCO	Chief Compliance Officer
CEO	Chief Executive Officer
CRO	Chief Risk Officer
COSO	Committee of Sponsoring Organisations
CMP	Compliance Monitoring Programme

CRA	Compliance Risk Assessment
DMS	Document Management System
EDMF	Ethical Decision-Making Framework
EU	European Union
FATF	Financial Action Task Force
FICC	Fixed Income, Currencies and Commodities
FSB	Financial Stability Board
FTC	Fair Treatment of Customers
GC	General Counsel
G-SIB	Globally Systemically Important Bank
HMRC	His Majesty's Revenue & Customs
ISO	International Organisation for Standardisation
KCRI	Key Compliance Risk Indicator
LMS	Learning Management System
MLA	Mutual Legal Assistance
OECD	Organisation for Economic Co-operation and Development
OFAC	Office of Foreign Assets Control
PAP	Product Approval Process
RCA	Root Cause Analysis
RCSA	Risk and Control Self-Assessment
RMI	Risk Management Information
SAR	Suspicious Activity Report
SCB	Stratum Capital Bank
SMCR	Senior Managers & Certification Regime
UN	United Nations

APPENDIX C — REGULATORY REFERENCES

The following regulatory frameworks, standards, and guidelines inform the design and content of this Chapter:

Reference	Relevance to Chapter 12
Basel Committee on Banking Supervision — Compliance and the Compliance Function in Banks (April 2005)	Primary framework for the design of the Bank's Compliance function and compliance risk management.

Basel Committee on Banking Supervision — Corporate Governance Principles for Banks (BCBS 328, July 2015)	Governance structure, Board responsibilities, and Three Lines of Defence model.
Basel Committee on Banking Supervision — Principles for the Sound Management of Operational Risk (June 2011)	Operational risk framework integration with compliance risk management.
Financial Action Task Force (FATF) — The FATF Recommendations (2012, as updated)	AML/CFT compliance obligations, risk-based approach, and customer due diligence requirements.
FATF — Guidance for a Risk-Based Approach — Banking Sector (2014)	Risk-based AML compliance and customer risk assessment.
ISO 37301:2021 — Compliance Management Systems	End-to-end compliance management system design and operation.
ISO 37001:2016 — Anti-Bribery Management Systems	Anti-bribery and anti-corruption framework design.
ISO 31000:2018 — Risk Management	Risk management principles integrated with compliance risk framework.
OECD G20/OECD Principles of Corporate Governance (2023)	Board governance, shareholder rights, stakeholder engagement, and disclosure standards.
OECD Convention on Combating Bribery of Foreign Public Officials (1997, as amended)	Anti-bribery obligations applicable to international operations.
COSO — Internal Control — Integrated Framework (2013)	Internal control framework underpinning compliance monitoring and policy governance.
COSO — Enterprise Risk Management — Integrating with Strategy and Performance (2017)	ERM integration with compliance risk management.
Financial Stability Board — Principles for Sound Compensation Practices (2009)	Conduct risk framework and employee incentive management.
FX Global Code (2021)	Market conduct standards for foreign exchange activities.

APPENDIX D — ROLES & RESPONSIBILITIES MATRIX

The following matrix summarises the primary roles and responsibilities for key compliance governance activities. A = Accountable; R = Responsible; C = Consulted; I = Informed.

Activity	Board	CEO	CCO	CRO	BU	IA
Framework Approval	A	R	R	C	I	I
Compliance Risk Assessment	I	I	A	C	R	I
Regulatory Monitoring	I	I	A	C	R	I
Compliance Monitoring & Testing	I	I	A	C	C	I
Breach Identification & Escalation	I	I	A	C	R	I
Regulatory Notification	A	R	R	C	I	I
Policy Approval (Enterprise)	A	C	R	C	I	I

Policy Approval (Divisional)	I	A	R	C	R	I
Training Programme Delivery	I	I	A	C	R	I
Whistleblowing Investigation	I	I	A	C	I	I
Third Party Due Diligence	I	I	A	C	R	I
Board Compliance Reporting	A	C	R	C	I	I
Audit of Compliance Framework	I	I	C	C	C	A
Lessons Learned Review	I	I	A	C	R	C
Annual Framework Certification	A	R	R	C	I	I

Key: A = Accountable | R = Responsible | C = Consulted | I = Informed | BU = Business Units | IA = Internal Audit

APPENDIX E — POLICY REVIEW SCHEDULE

Policy / Chapter	Document Owner	Review Cycle	Next Review	Approval Authority
Chapter 1 — Enterprise Governance	Chief Governance Officer	Annual	Dec 2025	Board
Chapter 2 — Enterprise Risk	Chief Risk Officer	Annual	Dec 2025	Board
Chapter 3 — Credit Governance	Chief Credit Officer	Annual	Dec 2025	Board
Chapter 4 — Treasury & Capital	Group Treasurer	Annual	Dec 2025	Board
Chapter 5 — Fraud Governance	Head of Financial Crime	Annual	Dec 2025	Board
Chapter 6 — Operational Risk	Chief Risk Officer	Annual	Dec 2025	Board
Chapter 7 — Internal Controls	Head of Internal Controls	Annual	Dec 2025	Board
Chapter 8 — Data Governance	Chief Data Officer	Annual	Dec 2025	Board
Chapter 9 — AI Governance	Chief AI & Model Risk Officer	Annual	Dec 2025	Board
Chapter 10 — Cyber Security	Chief Information Security Officer	Annual	Dec 2025	Board
Chapter 11 — Business Continuity	Chief Operating Officer	Annual	Dec 2025	Board
Chapter 12 — Compliance & Ethics	Chief Compliance Officer	Annual	Dec 2025	Board
Code of Conduct	Chief Compliance Officer	Annual	Dec 2025	Board
AML Policy	Head of Financial Crime	Annual	Dec 2025	BRCC

Conflict of Interest Policy	Chief Compliance Officer	Annual	Dec 2025	ExCo
Gift & Hospitality Policy	Chief Compliance Officer	Annual	Dec 2025	ExCo
Whistleblowing Policy	Chief Compliance Officer	Annual	Dec 2025	Board
Outsourcing Policy	Chief Risk Officer	Annual	Dec 2025	Board

APPENDIX F — ENTERPRISE GOVERNANCE HIERARCHY

The following diagram represents the enterprise governance hierarchy of Stratum Capital Bank for compliance governance purposes:



APPENDIX G — DOCUMENT CONTROL REGISTER

Document Reference	Title	Current Version	Next Review
SCB-GOV-CH12-v5.4.1	Chapter 12 — Compliance & Ethics Framework	5.4.1	Dec 2025
SCB-GOV-CH01-v5.4.0	Chapter 1 — Enterprise Governance	5.4.0	Dec 2025
SCB-GOV-CH02-v5.4.0	Chapter 2 — Enterprise Risk Management	5.4.0	Dec 2025
SCB-GOV-CH03-v5.4.0	Chapter 3 — Credit Governance	5.4.0	Dec 2025

SCB-GOV-CH04-v5.4.0	Chapter 4 — Treasury & Capital	5.4.0	Dec 2025
SCB-GOV-CH05-v5.4.0	Chapter 5 — Fraud Governance	5.4.0	Dec 2025
SCB-GOV-CH06-v5.4.0	Chapter 6 — Operational Risk	5.4.0	Dec 2025
SCB-GOV-CH07-v5.4.0	Chapter 7 — Internal Controls	5.4.0	Dec 2025
SCB-GOV-CH08-v5.4.0	Chapter 8 — Data Governance	5.4.0	Dec 2025
SCB-GOV-CH09-v5.4.0	Chapter 9 — AI Governance	5.4.0	Dec 2025
SCB-GOV-CH10-v5.4.0	Chapter 10 — Cyber Security	5.4.0	Dec 2025
SCB-GOV-CH11-v5.4.0	Chapter 11 — Business Continuity	5.4.0	Dec 2025
SCB-COD-001-v3.2	Code of Conduct	3.2	Dec 2025
SCB-AML-POL-001-v4.1	AML Policy	4.1	Dec 2025
SCB-COI-POL-001-v2.3	Conflict of Interest Policy	2.3	Dec 2025
SCB-GH-POL-001-v2.1	Gift & Hospitality Policy	2.1	Dec 2025
SCB-WB-POL-001-v3.0	Whistleblowing Policy	3.0	Dec 2025
SCB-OUT-POL-001-v2.4	Outsourcing Policy	2.4	Dec 2025
SCB-RET-POL-001-v2.0	Records Retention Policy	2.0	Dec 2025
SCB-PI-POL-001-v1.8	Personal Investment Policy	1.8	Dec 2025

— END OF CHAPTER 12 APPENDICES —

Enterprise Governance & Risk Framework | Chapter 12 — Enterprise Regulatory Compliance, Legal Governance & Corporate Ethics Framework

Version 5.4.1 | Effective 1 January 2025 | CONFIDENTIAL — INTERNAL USE ONLY

Stratum Capital Bank N.V. | Approved by: Board of Directors — Resolution No. SCB/BRD/2024/147